

AUTHENTICATION AND SESSION ANALYSIS

Beginner Authentication lab using Burp Suite

Assignment: Authentication lab – Login Behaviour and Session/Cookie
Analysis

NAME: Iresh Chirantha

Platform: PortSwigger academy

Tools: Burp Suite

Table of Contents

Contents

1). Introduction.....	3
2). Objectives.	4
3). Lab Environment.....	5
4). Methodology.....	6
5). Authentication analysis.	7
5.1). Before authentication	7
5.2). Login request.....	8
.....	8
5.3). After authentication.	9
5.4). Session/Cookie comparison.	11
6). Results.	12
7). Security observations	13
8). Conclusion.	14

1). Introduction.

Authentication is the process of verifying the identity of a user before allowing access to protected resources. Web applications commonly use sessions and cookies to maintain a user's authenticated state.

This practical exercise used Burp Suite to observe the authentication process of an authorized web application. The HTTP requests and responses were inspected before and after login, with particular attention given to session cookies and changes in their values.

2). Objectives.

The main objectives of this practical were:

- To understand the basic web authentication process.
- To capture HTTP requests using Burp Suite.
- To observe the login request sent by the browser.
- To examine session cookies before and after authentication.
- To compare session values before and after successful authentication.
- To understand how sessions maintain an authenticated state.

3). Lab Environment.

Component	Details
Operating system	Windows
Browser	Firefox/Burp browser
Security tool	Burp Suite
Target	Authorized authentication lab
Testing type	Authentication/session observation

4). Methodology.

The authentication lab was opened using a browser configured through Burp Suite. Burp Suite Proxy and HTTP history were used to capture and inspect the application's HTTP traffic.

First, the login page was accessed without authentication. The HTTP request and response were inspected to identify any session cookie created by the application.

Next, the credentials supplied by the lab were entered into the login form. The resulting login request was captured using Burp Suite. The request method, endpoint, parameters and session cookie were then examined.

After successful authentication, the server response and subsequent authenticated request were inspected. The session cookie before authentication was compared with the session cookie after authentication.

5). Authentication analysis.

5.1). Before authentication.

The image shows two screenshots. The top screenshot is a web browser displaying the Web Security Academy login page. The URL is `https://0a3700be03bbb41c814eac2f000c0049.web-security-academy.net/login`. The page has a header with the Web Security Academy logo, the title "Brute-forcing a stay-logged-in cookie", and a "LAB Not solved" status. Below the header is a "Login" form with fields for "Username", "Password", and a "Stay logged in" checkbox. A "Log in" button is at the bottom of the form. The bottom screenshot is a screenshot of the Burp Suite interface. The "Repeater" tab is active, showing an HTTP request to `/login`. The request is a GET request with the following headers: `Host: 0a3700be03bbb41c814eac2f000c0049.web-security-academy.net`, `Cookie: session=NfCJ8VMuvsIGCvmFMd3fkUJrT8Zc8RxM`, `Accept-Language: en-US,en;q=0.9`, `Upgrade-Insecure-Requests: 1`, `User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36`, `Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7`, `Sec-Fetch-Site: same-origin`, `Sec-Fetch-Mode: navigate`, `Sec-Fetch-User: ?1`, `Sec-Fetch-Dest: document`, `Sec-Ch-UA: "Not;A=Brand";v="0", "Chromium";v="150"`, `Sec-Ch-UA-Mobile: 70`, `Sec-Ch-UA-Platform: "Windows"`, `Referer: https://0a3700be03bbb41c814eac2f000c0049.web-security-academy.net/`, `Accept-Encoding: gzip, deflate, br`, `Priority: u=0, i`. The "Inspector" panel on the right shows the request attributes, query parameters, body parameters, cookies, and headers.

Before logging into the application, the login page was accessed and the HTTP traffic was captured using Burp Suite.

The application issued a session cookie:

Session=NfCJ8VMuvsIGCvmFMd3fkUJrT8Zc8RxM

This cookie was recorded as the pre-authentication session identifier.

5.2). Login request.

The screenshot displays the Burp Suite interface. The top menu bar includes 'Burp', 'Project', 'Intruder', 'Repeater', 'View', and 'Help'. Below the menu is a toolbar with icons for various functions. The main window is divided into several panes. The 'HTTP history' pane shows a list of intercepted requests. The selected request (index 24) is a POST to '/login' with a status code of 302. The 'Request' pane shows the raw HTTP request details, including headers like 'Host: 0af600d90386378008fd1500ca00ce.web-security-academy.net', 'Cookie: session=90lk2Z9aCH8DSxmtzsh45nhD5ec0WKF9', and 'Content-Type: application/x-www-form-urlencoded'. The 'Response' pane shows the raw HTTP response details, including headers like 'HTTP/2 302 Found', 'Location: /my-account?id=wiener', and 'Set-Cookie: stay-logged-in=d21lha7y0j0a2CH8DSxmtzsh45nhD5ec0WKF9; Expires=Wed, 01 Jan 2000 01:00:00 UTC'. The 'Inspector' pane on the right shows the request attributes, body parameters, cookies, headers, and response headers.

#	Host	Method	URL	Para...	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start respon...
1	https://0af600d90386378008fd1500ca00ce.web-security-academy.net	GET	/			200	8496	HTML		Brute-forcing a stay-lo...		✓	79.125.84.16	session=90lk2Z9aCH8DSxmtzsh45nhD5ec0WKF9	10:01:07 15 ...	8080	244
15	https://0af600d90386378008fd1500ca00ce.web-security-academy.net	GET	/academylabheader			101	147					✓	79.125.84.16		10:01:09 15 ...	8080	227
20	https://0af600d90386378008fd1500ca00ce.web-security-academy.net	GET	/my-account			302	86					✓	79.125.84.16		10:01:12 15 ...	8080	216
21	https://0af600d90386378008fd1500ca00ce.web-security-academy.net	GET	/login			200	3454	HTML		Brute-forcing a stay-lo...		✓	79.125.84.16		10:01:12 15 ...	8080	223
23	https://0af600d90386378008fd1500ca00ce.web-security-academy.net	GET	/academylabheader			101	147					✓	79.125.84.16		10:01:13 15 ...	8080	377
31	https://0af600d90386378008fd1500ca00ce.web-security-academy.net	GET	/academylabheader			101	147					✓	79.125.84.16		10:02:46 15 ...	8080	197
24	https://0af600d90386378008fd1500ca00ce.web-security-academy.net	POST	/login		✓	302	308					✓	79.125.84.16	stay-logged-in=d...	10:02:44 15 ...	8080	279
25	https://0af600d90386378008fd1500ca00ce.web-security-academy.net	GET	/my-account?id=wiener		✓	200	3363	HTML		Brute-forcing a stay-lo...		✓	79.125.84.16		10:02:46 15 ...	8080	198

Request

1 POST /login HTTP/2
2 Host: 0af600d90386378008fd1500ca00ce.web-security-academy.net
3 Cookie: session=90lk2Z9aCH8DSxmtzsh45nhD5ec0WKF9
4 Content-Length: 49
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: en-US,en;q=0.9
10 Upgrade-Insecure-Requests: 1
11 Content-Type: application/x-www-form-urlencoded
12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
13 Origin: https://0af600d90386378008fd1500ca00ce.web-security-academy.net
14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document

Response

1 HTTP/2 302 Found
2 Location: /my-account?id=wiener
3 Set-Cookie: stay-logged-in=d21lha7y0j0a2CH8DSxmtzsh45nhD5ec0WKF9; Expires=Wed, 01 Jan 2000 01:00:00 UTC
4 Set-Cookie: session=90lk2Z9aCH8DSxmtzsh45nhD5ec0WKF9; Secure; HttpOnly; SameSite=None
5 X-Frame-Options: SAMEORIGIN
6 Content-Length: 0

Inspector

Request attributes: 2
Request body parameters: 3
Request cookies: 1
Request headers: 23
Response headers: 5

Event log All issues Memory: 154.4MB of 6.92GB Disabled

The login request was captured using Burp Suite HTTP history.

The request used the following method:

POST

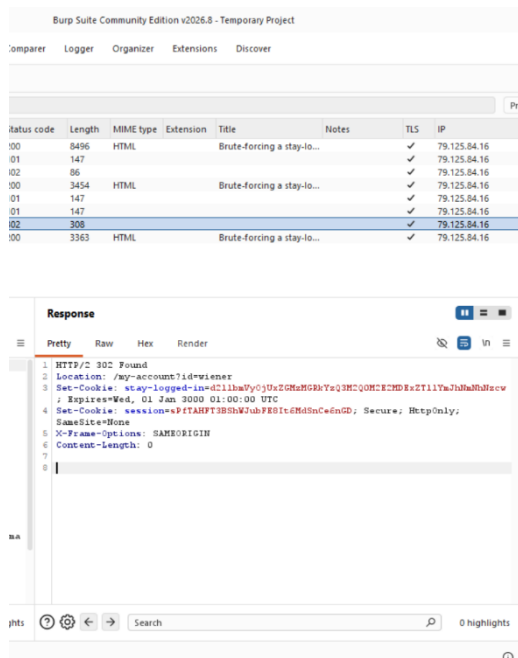
The authentication endpoint was:

/LOGIN

The request contained the username and password parameters supplied by the lab.

For security and privacy, the password is redacted in this report.

5.3). After authentication.



After submitting valid credentials, the server returned a response indicating that authentication was successful.

The response was inspected for session-related information, particularly the Set-Cookie header.

The authenticated session value was:

Session =sPftAHFT3BShWJubFE8lt6MdSnCe6nGD

The authenticated page was then accessed, and Burp Suite showed that the session cookie was sent with the request.

1

Burp

Project

Intruder

Repeater

View

Help

Burp Suite Community Edition v2026.8 - Temporary Project

Dashboard

Target

Proxy

Intruder

Repeater

Collaborator

Sequencer

Decoder

Comparer

Logger

Organizer

Extensions

Discover

Intercept

HTTP history

WebSockets history

Match and replace

Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions

Pro version only

Filter on

#	Host	Method	URL	Para...	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start respon...
1	https://0af600d90386363780...	GET	/			200	8496	HTML		Brute-forcing a stay-lo...		✓	79.125.84.16	session=90lk2Xk...	10:01:07 15 ...	8080	244
15	https://0af600d90386363780...	GET	/academyLabHeader			101	147					✓	79.125.84.16		10:01:09 15 ...	8080	227
20	https://0af600d90386363780...	GET	/my-account			302	86					✓	79.125.84.16		10:01:12 15 ...	8080	216
21	https://0af600d90386363780...	GET	/login			200	3454	HTML		Brute-forcing a stay-lo...		✓	79.125.84.16		10:01:12 15 ...	8080	223
23	https://0af600d90386363780...	GET	/academyLabHeader			101	147					✓	79.125.84.16		10:01:13 15 ...	8080	377
31	https://0af600d90386363780...	GET	/academyLabHeader			101	147					✓	79.125.84.16		10:02:46 15 ...	8080	197
24	https://0af600d90386363780...	POST	/login			302	308					✓	79.125.84.16	stay-logged-in=d...	10:02:46 15 ...	8080	279
25	https://0af600d90386363780...	GET	/my-account?id=wiener		✓	200	3363	HTML		Brute-forcing a stay-lo...		✓	79.125.84.16		10:02:46 15 ...	8080	198

Request

Response

Inspector

Pretty

Raw

Hex

IN

1

GET

/my-account?id=wiener

HTTP/2

2

Host:

0af600d9038636378088fd1500ca00ce.web-security-academy.net

3

Cookie:

stay-logged-in=4211ba7y0jUe2Q2kaMG28YqQ2MC2QMC2NDEx2T1lYa7hNalHdHecw; session=8PFTAHPT3B5bW2abF80ic6Hd5nCe6nGD

4

Cache-Control:

max-age=0

5

Accept-Language:

en-US,en;q=0.9

6

Upgrade-Insecure-Requests:

1

7

User-Agent:

Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36

8

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

9

Sec-Fetch-Site:

same-origin

10

Sec-Fetch-Mode:

navigate

11

Sec-Fetch-User:

?1

12

Sec-Fetch-Dest:

document

13

Sec-Ch-UA:

"Chromium",v="151", "Not-A.Brand",v="99"

14

Sec-Ch-UA-Mobile:

?0

15

Sec-Ch-UA-Platform:

"Windows"

16

Referer:

https://0af600d9038636378088fd1500ca00ce.web-security-academy.net/login

1

HTTP/2

200 OK

2

Content-Type:

text/html; charset=utf-8

3

Cache-Control:

no-cache

4

X-Frame-Options:

SAMEORIGIN

5

Content-Length:

3230

6

7

<!DOCTYPE html>

8

<html>

9

<!--LAB_HEAD_START-->

10

<head>

11

<link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>

12

<link href=/resources/css/labs.css rel=stylesheet>

13

<title>

14

</title>

15

</head>

16

<!--LAB_HEAD_END-->

17

<body>

18

<script src=/resources/labheader/js/labHeader.js>

19

</script>

20

<!--LAB_HEADER_START-->

21

<div>

22

</div>

23

</body>

24

<!--LAB_HEADER_END-->

25

</html>

Request attributes

2

Request query parameters

1

Request cookies

2

Request headers

21

Response headers

4

Event log

All issues

Memory: 160.8MB of 6.92GB

Disabled

10:26 AM

15/09/2026

5.4). Session/Cookie comparison.

The session values observed during the test were compared as follows:

Stage	Session/Cookie value	Observation
Before login	NfCJ8VMuvslGCvmFMd3fkUJrT8Zc8RxM	Pre-authentication session
Login request	NfCJ8VMuvslGCvmFMd3fkUJrT8Zc8RxM	Existing session sent with login request
After login	sPftAHFT3BShWJubFE8lt6MdSnCe6nGD	Session value observed after authentication
Authenticated request	sPftAHFT3BShWJubFE8lt6MdSnCe6nGD	Session used to maintain authenticated state.

If the session value changed, this indicates that the application regenerated or replaced the session identifier during authentication. If it remained unchanged, the observation should be recorded without automatically concluding that a vulnerability exists.

6). Results.

The authentication process was successfully observed using Burp Suite. The login request and server response were captured and inspected.

The session cookie was identified before authentication and compared with the value used after authentication. The authenticated request demonstrated how the session cookie was subsequently used to maintain the user's authenticated state.

7). Security observations.

The following observations were made:

1. The login process was transmitted as an HTTP request that could be inspected using Burp Suite.
2. A session cookie was associated with the user's session.
3. The session value before and after authentication was compared.
4. The authenticated session was subsequently included in requests to protected resources.
5. Cookie security attributes such as Secure and HttpOnly were checked where visible.

The observed behavior should be interpreted within the scope of this lab. A change or lack of change in the session identifier alone does not establish a security vulnerability.

8). Conclusion.

This practical provided an introduction to web authentication and session management using Burp Suite. HTTP requests and responses were successfully captured and examined before and after authentication.

The exercise demonstrated how cookies can be used to maintain a user's session and how comparing session values can provide useful information about an application's authentication behavior. Burp Suite was useful for observing the communication between the browser and the web application without modifying the application's behavior.